

BUILD WEEK 3 // BONUS 3

Splunk Hunting

Analisi di log di sicurezza con Splunk Enterprise:
identificazione di tentativi di accesso falliti,
sessioni SSH legittime, attivita' di brute force
e errori server.

Splunk Enterprise 10.4.0 | SPL | tutorialdata.zip

ESERCITAZIONE	Bonus 3 -- Splunk Hunting
AMBIENTE	Splunk Enterprise 10.4.0 su Windows Server
DATASET	tutorialdata.zip (Splunk Tutorial Data)
STRUMENTO	Splunk Search Processing Language (SPL)
AUTORE	_____
DATA	_____



00

Indice

01 Obiettivi

02 Dataset e ambiente

03 Query 1 -- Tentativi di accesso falliti (Failed password)

3.1 Obiettivo

3.2 Query SPL

3.3 Risultato

04 Query 2 -- Sessioni SSH riuscite per djohnson

4.1 Obiettivo

4.2 Query SPL

4.3 Risultato

05 Query 3 -- Tentativi falliti dall'IP 86.212.199.60

5.1 Obiettivo

5.2 Query SPL

5.3 Risultato

06 Query 4 -- Rilevamento attacchi brute force

6.1 Obiettivo

6.2 Query SPL

6.3 Risultato

07 Query 5 -- Internal Server Error (HTTP 500)

7.1 Prima ricerca -- Stringa letterale

7.2 Seconda ricerca -- Codice di stato HTTP 500

7.3 Risultato

08 Fase di analisi e Incident Response

8.1 Correlazione dei risultati

8.2 Verifica di compromissioni post-brute force

8.3 Raccomandazioni

09 Conclusioni

01

Obiettivi

L'obiettivo di questo laboratorio e' sviluppare competenze pratiche nell'utilizzo di Splunk per l'analisi dei log di sicurezza. Il dataset tutorialdata.zip contiene log di sistema, log di accesso SSH e log di un web server, che simulano uno scenario reale con attivita' sia legittime che malevole.

Le attivita' richieste sono:

- **1.** Creare una query per identificare i tentativi di accesso falliti ("Failed password") con timestamp, IP sorgente, username e motivo del fallimento
- **2.** Trovare le sessioni SSH aperte con successo per l'utente "djohnson" con timestamp e ID utente
- **3.** Trovare i tentativi falliti dall'IP "86.212.199.60" con timestamp, username e porta
- **4.** Creare una query per rilevare attacchi brute force: IP con piu' di 5 tentativi falliti e relativo conteggio
- **5.** Isolare tutti gli "Internal Server Error" nel dataset

02

Dataset e ambiente

Il dataset tutorialdata.zip e' stato importato in Splunk Enterprise tramite la funzione **Add Data > Upload**. Il file contiene log eterogenei provenienti da diverse sorgenti: log di autenticazione SSH (secure.log / auth.log), log di accesso web (access.log) e altri log di sistema.

L'intervallo temporale utilizzato per tutte le query e' **All time**, per garantire la copertura completa del dataset.

Voce	Valore
Versione Splunk	Enterprise 10.4.0
Dataset	tutorialdata.zip
Indice	Predefinito (main)
Time Range	All time
Sorgenti principali	secure.log, access.log

03

Query 1 -- Failed password

- Obiettivo

Identificare tutti gli eventi in cui un tentativo di autenticazione SSH e' fallito, estraendo timestamp, indirizzo IP sorgente, username tentato e porta.

- Query SPL

```
index=* "Failed password"
| rex "Failed password for (?<username>\S+) from (?<src_ip>\S+) port (?<src_port>\S+)"
| table _time, src_ip, username, src_port
| rename _time AS "Timestamp", src_ip AS "IP Sorgente", username AS "Username", src_port AS "Porta"
```

- Risultato

La query ha restituito **33.253 eventi** contenenti la stringa "Failed password". L'elevato numero di tentativi falliti indica chiaramente la presenza di attivita' di brute force massiva nel dataset.

Tra gli IP sorgente piu' ricorrenti si notano:

- 123.30.108.208 -- tentativi verso l'utente root
- 128.241.220.82 -- tentativi verso root e prince
- Numerosi altri IP distribuiti geograficamente

Il campo rex (regular expression extraction) e' stato utilizzato per estrarre dinamicamente username, IP e porta dalla stringa di log, che segue il formato standard di syslog per i messaggi di autenticazione SSH.

Timestamp	IP Sorgente	Username	Porta
1781588775			
1781588775			
1781588775			
1781588775	123.30.108.208	root	2295
1781588775			
1781588775	128.241.220.82	root	3117
1781588775			
1781588775	128.241.220.82	prince	2481
1781588775	128.241.220.82	root	1819
1781588775			
1781588775			
1781588775			
1781588775			
1781588775			
1781588775			

Figura 1. Risultato della Query 1: 33.253 tentativi di accesso falliti con IP sorgente, username e porta estratti tramite regex.

04

Query 2 -- Sessioni djohnson

- **Obiettivo**

Identificare tutte le sessioni SSH aperte con successo dall'utente "djohnson", con timestamp e IP sorgente.

- **Query SPL**

```
index=* "Accepted" "djohnson"
| rex "Accepted \S+ for (?<username>\S+) from (?<src_ip>\S+) port (?<src_port>\S+)"
| table _time, username, src_ip
| rename _time AS "Timestamp", username AS "ID Utente", src_ip AS "IP Sorgente"
```

- Risultato

La query ha restituito **955 eventi** di accesso riuscito per l'utente djohnson. Tutte le sessioni provengono dallo stesso indirizzo IP: **10.3.10.46**.

Questo pattern e' coerente con un utilizzo legittimo: un singolo utente che accede ripetutamente dallo stesso host interno. L'IP 10.3.10.46 appartiene a un range privato RFC 1918, il che conferma che si tratta di accessi dalla rete interna.

Se l'IP fosse variato frequentemente o provenisse da range esterni, sarebbe stato un indicatore di possibile compromissione dell'account.

The screenshot shows the Splunk web interface. At the top, there's a navigation bar with tabs like "UTM", "File", "Modifica", etc., and a status bar indicating "Windows_Server". Below the navigation bar, there's a search bar containing the query: `index=\* Accepted" djohnson" | rex "Accepted \\${?username}" from "{%rc\_ip%\\$?" port="{%rc\_port%\\$?" | table \_time, username, src\_ip | rename \_time AS "Timestamp", username AS "ID Utente", src\_ip AS "IP Sorgente"`. The search results are displayed as a table with three columns: "Timestamp", "ID Utente", and "IP Sorgente". The table contains multiple rows of data, all showing the same values: "1782161574" for Timestamp, "djohnson" for ID Utente, and "10.3.10.46" for IP Sorgente. The interface also includes various controls like "No Event Sampling", "Job", and "Smart Mode".

Figura 2. Risultato della Query 2: 955 sessioni SSH riuscite per djohnson, tutte dall'IP interno 10.3.10.46.

05

Query 3 -- IP 86.212.199.60

- **Obiettivo**

Isolare tutti i tentativi di accesso falliti provenienti da un IP specifico sospetto (86.212.199.60), con timestamp, username tentato e porta.

- **Query SPL**

```
index=* "Failed password" "86.212.199.60"  
| rex "Failed password for (?<username>\S+) from (?<src_ip>\S+) port (?<src_port>\S+)"  
| table _time, username, src_port  
| rename _time AS "Timestamp", username AS "Username", src_port AS "Porta"
```

- **Risultato**

La query ha restituito **158 tentativi falliti** dall'IP 86.212.199.60. Gli username tentati includono:

Username	Tipo di account
jira	Account applicativo (Jira)
nagios	Account di monitoraggio
mail	Account di servizio email
sync	Account di sistema
ncsd	Name Service Cache Daemon
games	Account di sistema legacy

Il pattern e' inequivocabile: l'attaccante sta enumerando account di servizio e di sistema, una tecnica tipica degli attacchi brute force automatizzati che utilizzano dizionari di username comuni. Nessuno dei tentativi ha avuto successo (non compaiono "Accepted" dallo stesso IP).

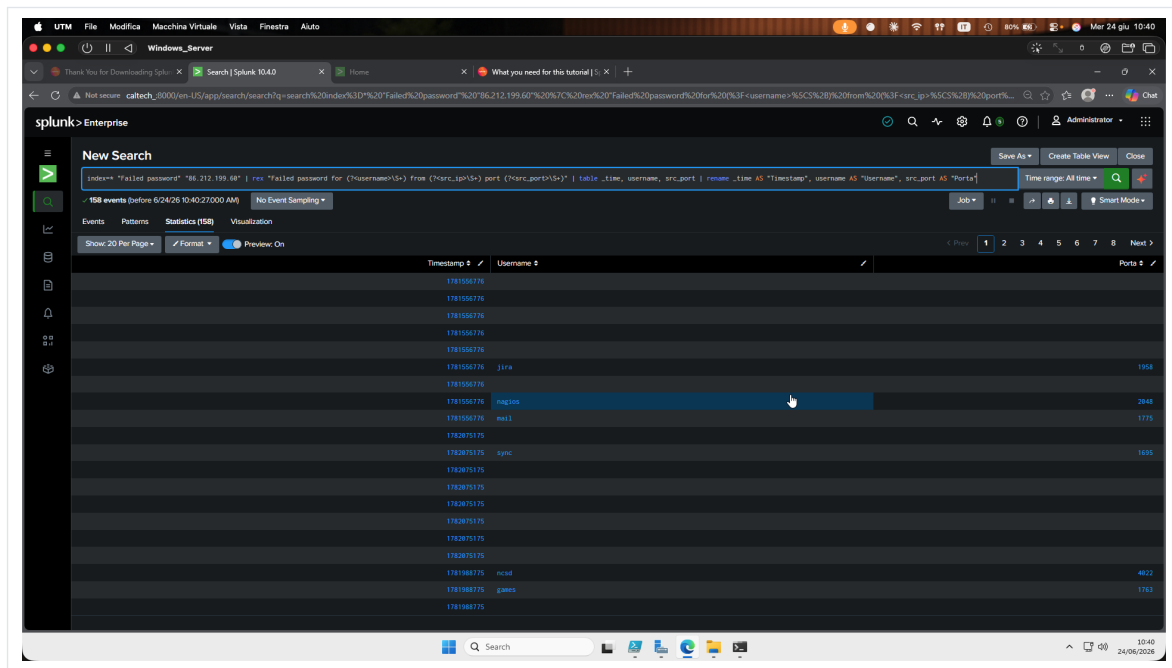


Figura 3. Risultato della Query 3: 158 tentativi falliti dall'IP 86.212.199.60 con enumerazione di account di servizio.

06

Query 4 -- Brute force

- Obiettivo

Identificare tutti gli indirizzi IP che hanno effettuato piu' di 5 tentativi di accesso falliti, ordinati per numero di tentativi decrescente.

- Query SPL

```
index=* "Failed password"
| rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"
| stats count AS tentativi BY src_ip
| where tentativi > 5
| sort -tentativi
| rename src_ip AS "IP Sorgente", tentativi AS "Tentativi Falliti"
```

- Risultato

La query ha identificato **185 indirizzi IP** con piu' di 5 tentativi falliti. I principali offender sono:

IP Sorgente	Tentativi Falliti	Osservazione
87.194.216.51	948	Attaccante piu' aggressivo
211.166.11.101	743	Secondo per volume
128.241.220.82	622	Terzo, gia' visto nella Query 1
109.169.32.135	515	
194.215.205.19	514	
216.221.226.11	433	
188.138.40.166	297	
65.19.167.94	286	

Il volume dei tentativi (fino a 948 da un singolo IP) e' nettamente superiore alla soglia di 5, confermando campagne di brute force automatizzate e prolungate. In un ambiente di produzione, questi IP andrebbero immediatamente inseriti in una blacklist firewall e segnalati tramite il SIEM.

Il comando `stats count BY src_ip` aggrega i risultati per IP sorgente, mentre `where tentativi > 5` filtra solo quelli che superano la soglia, e `sort -tentativi` ordina in modo decrescente per evidenziare i piu' aggressivi.

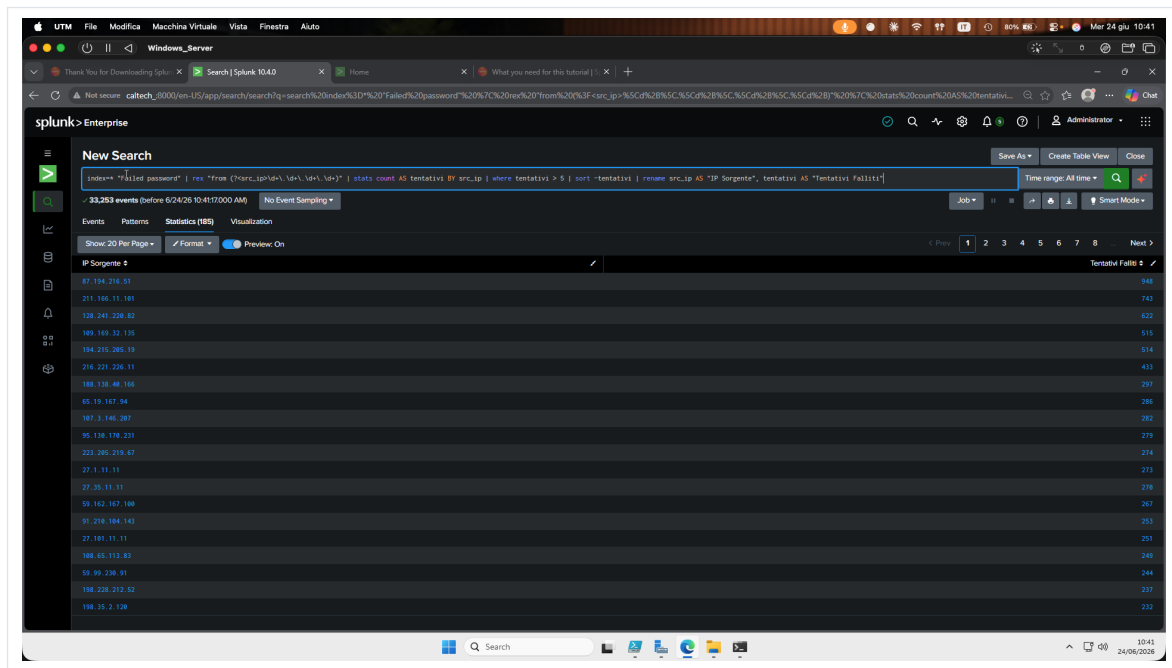


Figura 4. Risultato della Query 4: 185 IP con piu' di 5 tentativi falliti, ordinati per volume. Il top offender ha 948 tentativi.

07

Query 5 -- HTTP 500

- **Obiettivo**

Isolare tutti gli eventi di tipo "Internal Server Error" nel dataset.

- **Prima ricerca -- Stringa letterale**

La prima query ha cercato la stringa esatta "Internal Server Error":

```
index=* "Internal Server Error"
| table _time, source, sourcetype, host, _raw
```

Questa ricerca ha restituito **0 risultati**: il dataset non contiene la stringa letterale "Internal Server Error" nei log.

- **Seconda ricerca -- Codice di stato HTTP 500**

Poiche' nei log di accesso web gli errori HTTP vengono registrati come codice numerico e non come stringa testuale, la query e' stata adattata per cercare il codice di stato 500:

```
index=* status=500
| table _time, source, host, uri, status
| rename _time AS "Timestamp"
```

- **Risultato**

La query ha restituito **733 eventi** con codice HTTP 500. Tutti provengono dal web server **Caltech_** e dal file `access.log` (log del web server).

Le URI coinvolte includono:

Tipo di richiesta	Esempio URI	Occorrenze
Link obsoleti	/oldlink?itemId=EST-12&JSESSIONID;=...	Maggioranza
Operazioni carrello	/cart.do?action=view&itemId;=...	Frequenti
Pagine prodotto	/product.screen?productId=SF-BVS-G01&...	Presenti
Categorie	/category.screen?categoryId=NULL&...	Presenti

La presenza massiccia di errori 500 su `/oldlink` suggerisce un problema applicativo: link deprecati che puntano a risorse non piu' gestite dal backend. Gli errori su `/cart.do` e `/product.screen` indicano invece potenziali problemi di stabilita' dell'applicazione sotto carico o con parametri inattesi.

Il parametro `categoryId=NULL` nelle richieste a `/category.screen` e' particolarmente interessante: potrebbe indicare sia un bug dell'applicazione sia un tentativo di fuzzing da parte di un attaccante.

The screenshot displays the Splunk Enterprise interface. At the top, a search bar contains the query: `index=* status=500 | table _time, source, host, uri, status | rename _time AS "Timestamp"`. Below the search bar, the results are shown in a table format. The table has columns for `Timestamp`, `source`, `host`, `uri`, and `status`. The results show a list of 733 events, all with a status of 500. The sources are primarily `tutorialdata.zip` and `Caltech_`. The URIs include various endpoints like `/oldlink/` and `/cart.do`.

Timestamp	source	host	uri	status
1782834057	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-128785550ND=500L7FF40FF40282	500
1782829801	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-218785550ND=500L7FF40FF40301	500
1782827267	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-148785550ND=500L7FF40FF40376	500
1782827128	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-128785550ND=500L7FF40FF40392	500
1782816897	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-118785550ND=500L7FF40FF40363	500
1782815591	tutorialdata.zip	Caltech_	/cart.do?action=viewitemp=EST-188785550ND=500L7FF40FF40394	500
1782813449	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-188785550ND=500L7FF40FF40373	500
1782809968	tutorialdata.zip	Caltech_	/product.screen/productp=SF-895-5818785550ND=500L7FF40FF40353	500
1782809519	tutorialdata.zip	Caltech_	/product.screen/productp=SF-895-5818785550ND=500L7FF40FF40355	500
1781899581	tutorialdata.zip	Caltech_	/cart.do?action=purchaseitemp=EST-188785550ND=500L7FF40FF40348	500
1781898199	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-278785550ND=500L7FF40FF40348	500
1781891591	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-468785550ND=500L7FF40FF40388	500
1781890186	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-278785550ND=500L7FF40FF40695	500
1781887935	tutorialdata.zip	Caltech_	/cart.do?action=reviewitemp=EST-78785550ND=500L7FF40FF40524	500
1781886459	tutorialdata.zip	Caltech_	/product.screen/productp=SF-895-5818785550ND=500L7FF40FF40424	500
1781886458	tutorialdata.zip	Caltech_	/cart.do?action=viewitemp=EST-168785550ND=500L7FF40FF40424	500
1781971891	tutorialdata.zip	Caltech_	/category.screen/categoryp=PMALLA785550ND=500L7FF40FF40326	500
1781968656	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-278785550ND=500L7FF40FF40366	500
1781958457	tutorialdata.zip	Caltech_	/category.screen/categoryp=PMALLA785550ND=500L7FF40FF40315	500
1781953235	tutorialdata.zip	Caltech_	/oldlink/1cmdp=EST-78785550ND=500L7FF40FF40322	500

Figura 5. Risultato della Query 5: 733 errori HTTP 500 dal web server Caltech_, prevalentemente su URI di tipo /oldlink e /cart.do.

08

Analisi e Incident Response

- Correlazione dei risultati

Incrociando i dati delle cinque query emerge un quadro coerente:

- 1. Attacco brute force massivo e distribuito:** 33.253 tentativi di accesso falliti provenienti da 185 IP distinti con piu' di 5 tentativi ciascuno. Si tratta di una campagna automatizzata, probabilmente condotta tramite botnet.
- 2. Nessuna compromissione rilevata per djohnson:** l'utente djohnson accede esclusivamente dall'IP interno 10.3.10.46 con sessioni "Accepted". Non ci sono evidenze di accesso non autorizzato a questo account.
- 3. IP 86.212.199.60 confermato come attaccante:** 158 tentativi con enumerazione sistematica di account di servizio (jira, nagios, mail, sync). Nessun accesso riuscito dallo stesso IP.
- 4. Problemi applicativi sul web server:** 733 errori HTTP 500, non correlati agli attacchi SSH ma indicativi di instabilita' del backend web. Il parametro categoryId=NULL merita un'indagine separata per escludere tentativi di injection.

- Verifica di compromissioni post-brute force

Per verificare se qualcuno degli IP attaccanti sia riuscito ad accedere, si puo' eseguire una query incrociata:

```
index=* "Accepted"
| rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"
| search src_ip IN ("87.194.216.51", "211.166.11.101", "128.241.220.82", "86.212.199.60")
| table _time, src_ip
```

Se questa query restituisce 0 risultati, nessuno degli attaccanti principali ha ottenuto accesso. In caso contrario, sarebbe necessario avviare immediatamente un'indagine forense sull'host compromesso.

- Raccomandazioni

Azione	Priorita'	Motivazione
Blacklist dei top 10 IP attaccanti	Critica	Bloccare immediatamente le sorgenti di brute force piu' aggressive
Implementare fail2ban o equivalente	Critica	Ban automatico dopo N tentativi falliti (es. 5 in 10 minuti)
Abilitare autenticazione a chiave SSH	Alta	Disabilitare l'autenticazione via password per SSH
Investigare gli errori HTTP 500	Alta	Verificare se i parametri NULL sono tentativi di injection
Monitorare l'account djohnson	Media	Verificare che l'IP 10.3.10.46 sia effettivamente la workstation dell'utente
Configurare alerting Splunk	Media	Creare alert per soglie di tentativi falliti (es. >10 in 5 minuti)

Azione	Priorita'	Motivazione
Aggiornare il web server	Media	Risolvere i link obsoleti che generano errori 500

09

Conclusioni

L'analisi dei log tramite Splunk ha permesso di ricostruire un quadro completo della sicurezza dell'infrastruttura analizzata:

- **33.253 tentativi di accesso falliti** distribuiti su **185 IP** confermano una campagna di brute force attiva e distribuita
- L'IP piu' aggressivo (**87.194.216.51**) ha effettuato **948 tentativi**, evidenziando l'assenza di contromisure automatiche come fail2ban
- L'utente **djohnson** risulta un utente legittimo con pattern di accesso coerenti (955 sessioni dallo stesso IP interno)
- L'IP **86.212.199.60** e' un attaccante che enumera sistematicamente account di servizio (158 tentativi su jira, nagios, mail, sync)
- Il web server presenta **733 errori HTTP 500**, prevalentemente su link obsoleti, che richiedono manutenzione applicativa

Il valore di Splunk in questo contesto e' la capacita' di correlare eventi eterogenei (SSH auth + web access log) in un'unica piattaforma, permettendo di passare rapidamente dall'identificazione di un'anomalia alla comprensione del contesto completo dell'incidente. Le query SPL con rex, stats, where e sort si sono dimostrate strumenti fondamentali per l'analisi dei log nella threat hunting.

Report generato il 24 giugno 2026 -- Epicode Cybersecurity Bootcamp, Build Week 3